

Universidad de Lima
Facultad de Ingeniería
Carrera de Ingeniería de Sistemas



EQUIPO N° 3

Asignatura: Auditoría y Control de Sistemas

ESTUDIO DE CASO: SOL PERU S.A

Guido Alejandro Aquice Campos - 20213244

Piero Anchorena Campero - 20210113

Jose Alonso Matos Carpio - 20223709

Enzo Fabrizio Ordoñez Flores - 20221789

Paolo Arturo Rezza Nolazco - 20223947

Raúl Alexander Velazco Risco - 20222730

Docente: Jaddy Silvana Fernández Iparraguirre

Lima – Perú

16 de noviembre del 2025

Contenido

1	Responsabilidades del equipo de trabajo	5
2	Antecedentes	5
2.1	Selección de auditoría	6
2.1.1	Plantilla Selección auditoría	6
2.1.2	Justificación de la selección	13
3	Cronograma del trabajo de auditoría	14
4	Sujeto de auditoría	15
4.1	Explicación del sujeto de auditoría elegido	15
4.2	Actividades principales del proceso	15
5	Objetivo general de la auditoría	16
6	Alcance de la auditoría	16
7	Criterios de la auditoría	18
7.1	Explicación detallada del criterio 1	18
7.2	Explicación detallada del criterio 2	18
7.3	Explicación detallada del criterio 3	18
8	Objetivos específicos de la auditoría	19
8.1	Objetivo específico 1	19
8.2	Objetivo específico 2	19
8.3	Objetivo específico 3	19
9	Riesgos de auditoría – Controles existentes	19
9.1	Objetivo específico 1	20
9.1.1	Riesgo 1	20
9.2	Objetivo específico 2	21
9.2.1	Riesgo 2	21
9.3	Objetivo específico 3	23
9.3.1	Riesgo 3	23
10	Técnicas de pruebas de controles	25
10.1	Control 1	25
10.1.1	Técnica 1	25

10.1.2	Técnica 2	25
10.2	Control 2	25
10.2.1	Técnica 1	25
10.2.2	Técnica 2	25
10.3	Control 3	25
10.3.1	Técnica 1	25
10.3.2	Técnica 2	25
10.4	Control 4	25
10.4.1	Técnica 1	26
10.4.2	Técnica 2	26
10.5	Control 5	26
10.5.1	Técnica 1	26
10.5.2	Técnica 2	26
10.6	Control 6	26
10.6.1	Técnica 1	26
10.6.2	Técnica 2	26
10.7	Control 7	26
10.7.1	Técnica 1	26
10.7.2	Técnica 2	26
10.8	Control 8	27
10.8.1	Técnica 1	27
10.8.2	Técnica 2	27
10.9	Control 9	27
10.9.1	Técnica 1	27
10.9.2	Técnica 2	27
11	Fuentes de donde se va a tomar la evidencia	27
11.1	Fuente para la técnica 1	27
11.2	Fuente para la técnica 2	28
11.3	Fuente para la técnica 3	28
11.4	Fuente para la técnica 4	28

11.5	Fuente para la técnica 5	29
11.6	Fuente para la técnica 6	29
11.7	Fuente para la técnica 7	29
11.8	Fuente para la técnica 8	30
11.9	Fuente para la técnica 9	30
11.10	Fuente para la técnica 10	30
11.11	Fuente para la técnica 11	31
11.12	Fuente para la técnica 12	31
11.13	Fuente para la técnica 13	31
11.14	Fuente para la técnica 14	32
11.15	Fuente para la técnica 15	32
11.16	Fuente para la técnica 16	32
11.17	Fuente para la técnica 17	33
11.18	Fuente para la técnica 18	33
12	Informe de auditoría	34
12.1	Opinión de auditoría	34
12.2	Principales hallazgos	35
12.3	Recomendaciones	36
13	Referencias APA	37
14	Anexos	38

1 Responsabilidades del equipo de trabajo

Integrante	Responsabilidades	Fechas de inicio y fin
Guido Alejandro Aquice Campos	Completar la sección de Riesgos de auditoría - Controles existentes.	09/11/25 - 13/11/25
Piero Anchorena Campero	Completar la sección de Fuentes de donde se va a tomar la evidencia.	14/11/25 - 14/11/25
Jose Alonso Matos Carpio	Completar la sección de Criterios de la auditoría y Objetivos específicos de la auditoría.	09/11/25 - 13/11/25
Enzo Fabrizio Ordoñez Flores	Completar la sección de Antecedentes, Cronograma del trabajo de auditoría y Objetivo general de la auditoría.	09/11/25 - 13/11/25
Paolo Arturo Rezza Nolzco	Completar la sección de Sujeto de auditoría e Informe de auditoría.	14/11/25 - 14/11/25
Raúl Alexander Velazco Risco	Completar la sección de Técnicas de pruebas de controles y Alcance de la auditoría.	13/11/25 - 14/11/25

2 Antecedentes

SOL PERÚ S.A. es una reconocida compañía financiera especializada en servicios para MYPES, fundada con el objetivo de democratizar el acceso a productos de inversión para el segmento de pequeños empresarios peruanos. En marzo de 2025, la institución anunció con gran expectativa el lanzamiento de Finversión, una innovadora aplicación móvil que permitiría a sus clientes invertir en bolsa, bonos y fondos mutuos desde su smartphone en tiempo real, sin necesidad de intermediarios tradicionales.

El presente informe analiza el incidente ocurrido el 15 de abril de 2025, día del lanzamiento oficial, cuando más de 50,000 clientes intentaron ingresar simultáneamente a la aplicación, provocando fallas masivas que resultaron en la suspensión del servicio durante más de 48 horas. Este incidente generó un impacto mediático significativo, pérdida del 12% de clientes activos en inversiones, y múltiples reclamos ante la Superintendencia de Banca y Seguros (SBS).

La siguiente figura muestra la matriz de selección del universo de auditoría, donde se comparan tres procesos críticos de SOL PERÚ S.A. evaluados según su nivel de riesgo inherente. Finversión fue seleccionada como sujeto de auditoría prioritario debido a su clasificación de riesgo Extremo, derivada de 19 riesgos identificados (4 extremos, 12 altos y 3 moderados).

2.1 Selección de auditoría

2.1.1 Plantilla Selección auditoría

La siguiente figura muestra la matriz de selección del universo de auditoría, donde se comparan tres sujetos de auditoría de SOL PERÚ S.A. evaluados según su nivel de riesgo. Finversión fue seleccionada como sujeto de auditoría prioritario debido a su clasificación de riesgo Extremo, derivada de 19 riesgos identificados (4 extremos, 12 altos y 3 moderados).

Figura 1

Selección de Universo de sujeto de auditoría.

Proceso/Proyecto/Procedimiento	Numero de Riesgos Inherentes por calificación de Impacto y Probabilidad de Ocurrencia					Ponderación de Riesgos del Proceso (Cálculo - no tocar)	Programa Anual de Auditoría
	Extremo	Alto	Moderado	Bajo	Total		
Finversión	4	12	3	0	19	Extremo	Incluir en plan anual de auditoría
Seguridad de la Información	0	8	3	3	14	Alto	Incluir en auditoría posterior
Continuidad de Operaciones	0	11	2	2	15	Alto	Incluir en auditoría posterior

Fuente: Elaboración Propia. Anexo A

La siguiente tabla detalla los 43 riesgos inherentes identificados en el análisis del caso SOL PERÚ S.A., clasificados por sujeto de auditoría, nivel de probabilidad e impacto. Esta evaluación sustenta la selección de Finversión como prioridad de auditoría.

Tabla 1

Riesgos identificados del caso SOL PERÚ.

N°	Sujeto de auditoría	Riesgo	Probabilidad	Impacto	Nivel de riesgo (pxi)	Clasificación	Justificación
1	Finversión	Omisión crítica de pruebas de estrés y carga en servidores antes del lanzamiento	Casi seguro (0.9)	Catastrófico (1.0)	0.9	Extremo	No se realizaron pruebas de capacidad, causando colapso total de servidores con 50,000+ usuarios simultáneos,

							servicio caído 48+ horas.
2	FlInversión	Requisitos funcionales críticos inadecuadamente definidos por el Product Owner	Casi seguro (0.9)	Mayor (0.8)	0.72	Extremo	Product Owner no estableció historias de usuario claras ni criterios de aceptación, generando producto defectuoso.
3	FlInversión	Participación tardía de QA (solo última semana del sprint final)	Casi seguro (0.9)	Mayor (0.8)	0.72	Extremo	Área de QA ingresó al final, impidiendo detección temprana de defectos críticos.
4	FlInversión	Ausencia de mockups, wireframes y prototipo funcional validado	Casi seguro (0.9)	Mayor (0.8)	0.72	Extremo	Equipo desarrollo sin referencias visuales/técnicas validadas, aumentando retrabajo y errores.
5	FlInversión	Omisión de pruebas de usabilidad con usuarios reales	Casi seguro (0.9)	Mayor (0.8)	0.72	Alto	No se validó experiencia de usuario, resultando en interfaz confusa y errores operativos.
6	FlInversión	Ausencia de validación con usuarios piloto antes del lanzamiento masivo	Casi seguro (0.9)	Mayor (0.8)	0.72	Alto	Lanzamiento directo a 50,000+ usuarios sin fase beta o soft launch.
7	FlInversión	Falta de elaboración de casos de uso	Casi seguro (0.9)	Moderado (0.6)	0.54	Alto	Sin documentación de escenarios de uso para guiar desarrollo y

		documentados					pruebas.
8	FlInversión	Integración continua sin pipeline de pruebas automatizadas	Casi seguro (0.9)	Moderado (0.6)	0.54	Alto	CI/CD implementado sin testing automatizado ni control de versiones efectivo.
9	FlInversión	Presión por plazos de marketing compromete calidad del desarrollo	Probable (0.8)	Mayor (0.8)	0.64	Alto	Fecha de lanzamiento fijada por área de marketing forzó omisión de etapas críticas.
10	FlInversión	Roles y responsabilidades no claras en equipo Scrum	Probable (0.8)	Mayor (0.8)	0.64	Alto	Confusión de responsabilidades genera brechas en ejecución y calidad.
11	FlInversión	Falta de alineación entre negocio y tecnología	Probable (0.8)	Mayor (0.8)	0.64	Alto	Desconexión entre expectativas de negocio y capacidad técnica del equipo.
12	FlInversión	Cobertura insuficiente de casos de prueba funcionales	Probable (0.8)	Mayor (0.8)	0.64	Alto	Bugs críticos en producción no detectados por testing incompleto.
13	FlInversión	Ausencia de plan formal de gestión de riesgos del proyecto	Probable (0.8)	Mayor (0.8)	0.64	Alto	Riesgos críticos no identificados, evaluados ni mitigados proactivamente.
14	FlInversión	Falta de validación de criterios de aceptación	Probable (0.8)	Moderado (0.6)	0.48	Alto	Visión general sin detalle ni validación temprana genera desalineación.

		con stakeholder s					
15	FlInversión	Ausencia de entornos de prueba segregados equivalentes a producción	Probable (0.8)	Moderado (0.6)	0.48	Alto	Testing en ambientes no representativos oculta problemas reales.
16	FlInversión	Carencia de indicadores de calidad y métricas de desempeño del software	Probable (0.8)	Moderado (0.6)	0.48	Alto	Sin KPIs no hay visibilidad del estado real de calidad durante desarrollo.
17	FlInversión	Ausencia de Scrum Master efectivo facilitando el proceso ágil	Posible (0.6)	Moderado (0.6)	0.36	Moderado	Sin facilitador, equipo no aplica correctamente ceremonias y principios ágiles.
18	FlInversión	Backlog del producto mal priorizado o desactualizado	Posible (0.6)	Moderado (0.6)	0.36	Moderado	Equipo trabaja en funcionalidades incorrectas o de baja prioridad.
19	FlInversión	Falta de documentación técnica para mantenimiento futuro	Posible (0.6)	Menor (0.3)	0.18	Moderado	Ausencia de documentación dificulta soporte y evolución del sistema.
20	Seguridad de la Información	Errores en autenticación de usuarios durante	Probable (0.8)	Mayor (0.8)	0.64	Alto	Cierres automáticos de sesión detectados durante el incidente afectan seguridad.

		operaciones críticas					
21	Seguridad de la Información	Duplicación de operaciones ejecutadas compromete integridad de transacciones	Probable (0.8)	Mayor (0.8)	0.64	Alto	Operaciones duplicadas evidencian falta de controles de integridad transaccional.
22	Seguridad de la Información	Inconsistencia en datos de portafolios afecta confidencialidad	Probable (0.8)	Mayor (0.8)	0.64	Alto	Visualización incorrecta de información financiera sensible de clientes.
23	Seguridad de la Información	Falta de aplicación de criterios DevSecOps en desarrollo	Probable (0.8)	Mayor (0.8)	0.64	Alto	Seguridad no integrada desde inicio en ciclo de desarrollo del sistema.
24	Seguridad de la Información	Ausencia de pruebas de seguridad (SAST/DAST) antes del despliegue	Probable (0.8)	Mayor (0.8)	0.64	Alto	No se validaron vulnerabilidades de seguridad antes de lanzamiento.
25	Seguridad de la Información	Exposición de datos personales durante el incidente	Posible (0.6)	Mayor (0.8)	0.48	Alto	Múltiples reclamos ante SBS por operaciones no reconocidas sugieren exposición.
26	Seguridad de la Información	Controles de autorización débiles en	Posible (0.6)	Mayor (0.8)	0.48	Alto	Duplicación de transacciones indica falta de validaciones de

		operaciones de inversión					autorización.
27	Seguridad de la Información	Falta de cifrado en comunicaciones o datos en reposo	Posible (0.6)	Mayor (0.8)	0.48	Alto	No se menciona implementación de cifrado para datos financieros sensibles.
28	Seguridad de la Información	Ausencia de logs de auditoría para trazabilidad de operaciones	Posible (0.6)	Moderado (0.6)	0.36	Moderado	Dificulta investigación post-incidente y cumplimiento regulatorio.
29	Seguridad de la Información	Control de acceso inadecuado a datos de clientes	Posible (0.6)	Moderado (0.6)	0.36	Moderado	Principio de menor privilegio no implementado correctamente.
30	Seguridad de la Información	Falta de segregación de ambientes de desarrollo y producción	Posible (0.6)	Moderado (0.6)	0.36	Moderado	Riesgo de acceso no autorizado o contaminación entre ambientes.
31	Continuidad de Operaciones	Ausencia de pruebas de continuidad operativa previas a producción	Casi seguro (0.9)	Mayor (0.8)	0.72	Alto	SBS observa falta de validación de continuidad exigida para entidades financieras.
32	Continuidad de Operaciones	Falla masiva de servidores por más de 48 horas	Casi seguro (0.9)	Mayor (0.8)	0.72	Alto	Colapso de servidores requirió suspensión temporal del servicio, afectando continuidad.

33	Continuidad de Operaciones	Ausencia de plan documentado de respuesta a incidentes	Casi seguro (0.9)	Mayor (0.8)	0.72	Alto	Respuesta desorganizada requirió conformar Comité de Crisis reactivamente.
34	Continuidad de Operaciones	Capacidad de servidores subdimensionada para demanda esperada	Probable (0.8)	Mayor (0.8)	0.64	Alto	Servidores no soportaron carga de 50,000+ usuarios simultáneos.
35	Continuidad de Operaciones	Falta de plan de rollback ante fallas críticas	Probable (0.8)	Mayor (0.8)	0.64	Alto	Sin estrategia de reversión rápida, requirió retiro completo de app stores.
36	Continuidad de Operaciones	Ausencia de redundancia y alta disponibilidad en componentes críticos	Probable (0.8)	Mayor (0.8)	0.64	Alto	Puntos únicos de falla (SPOF) sin respaldo comprometen disponibilidad.
37	Continuidad de Operaciones	Falta de mecanismos de balanceo de carga en servidores	Probable (0.8)	Mayor (0.8)	0.64	Alto	Tráfico no distribuido eficientemente causó saturación de servidores.
38	Continuidad de Operaciones	Ausencia de monitoreo en tiempo real de recursos de servidores	Probable (0.8)	Moderado (0.6)	0.48	Alto	Sin visibilidad de CPU, memoria, I/O impide detección temprana de saturación.
39	Continuidad de Operaciones	Comunicación deficiente con clientes	Probable (0.8)	Moderado (0.6)	0.48	Alto	Falta de canal oficial agravó impacto reputacional y

		durante la crisis					desconfianza.
40	Continuidad de Operaciones	Falta de estrategia de despliegue gradual (piloto/canary)	Probable (0.8)	Moderado (0.6)	0.48	Alto	Lanzamiento masivo sin fase piloto expuso a todos usuarios simultáneamente.
41	Continuidad de Operaciones	Ausencia de backups probados y validados	Posible (0.6)	Mayor (0.8)	0.48	Alto	No se menciona validación de respaldos previo a lanzamiento crítico.
42	Continuidad de Operaciones	Tiempo de recuperación (RTO) no definido ni validado	Posible (0.6)	Moderado (0.6)	0.36	Moderado	Objetivos de recuperación no establecidos causó demoras de 48+ horas.
43	Continuidad de Operaciones	Falta de escalabilidad automática ante incrementos de demanda	Posible (0.6)	Moderado (0.6)	0.36	Moderado	Sistema no puede agregar recursos automáticamente ante picos de carga.

Fuente: Elaboración propia. Anexo B

2.1.2 Justificación de la selección

Se ha elegido auditar la aplicación móvil Flversión de SOL PERÚ S.A. porque es el sistema que concentra los riesgos más graves identificados en el incidente del 15 de abril de 2025. Estos riesgos incluyen omisión crítica de pruebas de capacidad, requerimientos funcionales inadecuadamente definidos, participación tardía del área de QA y ausencia de mockups validados.

Según nuestro análisis de riesgos, Flversión registra 19 riesgos inherentes (4 extremos, 12 altos y 3 moderados), con una ponderación final de nivel Extremo, posicionándolo como la máxima prioridad de auditoría en la organización.

La aplicación Flversión es crítica para la estrategia digital del banco, ya que permite a los clientes invertir en bolsa, bonos y fondos mutuos desde sus dispositivos móviles. El fallo masivo durante su lanzamiento no solo comprometió la funcionalidad de la aplicación, sino que puso en riesgo la confianza

de más de 50,000 clientes, la reputación institucional y el cumplimiento regulatorio ante la SBS, generando pérdidas financieras significativas y deterioro de la imagen corporativa.

Auditar FlInversión es la decisión más acertada porque cualquier mejora o fortalecimiento de controles que implementemos en esta aplicación servirá como caso de estudio y referencia para otros desarrollos tecnológicos del banco, previniendo incidentes similares en futuros proyectos digitales de SOL PERÚ S.A.

3 Cronograma del trabajo de auditoría

La siguiente tabla presenta el plan de auditoría correspondiente a la aplicación móvil FlInversión de SOL PERÚ S.A., seleccionada como sujeto de auditoría.

En ella se detallan los lineamientos temporales y las actividades clave agrupadas en las tres fases principales: Planificación, Ejecución y Comunicación. Este plan busca asegurar una ejecución ordenada y eficiente de la auditoría, garantizando la revisión integral de la aplicación más crítica identificada en la entidad financiera.

El cronograma abarca un período total de 11 días hábiles, iniciando el 4 de noviembre y concluyendo con la entrega del informe final el 16 de noviembre de 2025.

Tabla 2
Cronograma de auditoria.

CRONOGRAMA Y PLAZOS DE ENTREGA DE DOCUMENTOS				
Fase	Actividad Específica	Fecha de Inicio	Fecha de Fin	Duración
Fase 1: Planificación		04-nov	06-nov	3 días
	Entendimiento del caso y alcance del sujeto	04-nov	04-nov	1 día
	Análisis de Riesgos y Controles	05-nov	05-nov	1 día
	Diseño del Plan de Pruebas de Auditoría	06-nov	06-nov	1 días
Fase 2: Ejecución		07-nov	13-nov	5 días
	Pruebas de Requerimientos y QA	07-nov	08-nov	2 días
	Pruebas de Diseño y Usabilidad	09-nov	09-nov	1 día
	Pruebas de Entorno Técnico	10-nov	11-nov	2 días
	Consolidación y documentación de evidencia	12-nov	13-nov	2 días
Fase 3: Comunicación		14-nov	16-nov	3 días
	Análisis de hallazgos y redacción de borrador	14-nov	14-nov	1 días

	Revisión final y preparación de presentación	15-nov	15-nov	1 día
	Entrega de Informe Final	16-nov	16-nov	1 día

Nota: Elaboración Propia

4 Sujeto de auditoría

Nombre del sujeto de auditoría:

Aplicación móvil Finversión – Financiera SOL PERÚ S.A.

Tipo de auditoría:

Auditoría de **Seguridad de la Información y Continuidad Operativa** en el proceso de desarrollo, implementación y mantenimiento del sistema Finversión.

4.1 Explicación del sujeto de auditoría

El sujeto de auditoría es la aplicación móvil Finversión, desarrollada por la Financiera SOL PERÚ S.A. para permitir a sus clientes invertir en bolsa, bonos y fondos mutuos desde dispositivos móviles en tiempo real.

Aunque el sujeto es la aplicación, la auditoría abarca el proceso asociado a su desarrollo, pruebas, implementación y mantenimiento, debido a que este ciclo determina la calidad, seguridad y continuidad operativa del sistema.

Este proceso es crítico porque Finversión gestiona información financiera sensible, ejecuta operaciones en tiempo real y opera bajo el marco regulatorio de la Superintendencia de Banca y Seguros (SBS). Asimismo, afecta directamente la confianza y experiencia del cliente.

El ciclo involucra a diversas áreas: Tecnología, Desarrollo (Scrum), UX/UI, Seguridad de la Información, QA, Riesgos, Negocio y Soporte Técnico.

En el caso real se evidenciaron fallas graves como ausencia de pruebas de carga y estrés, inexistencia de prototipos validados, participación tardía de QA, falta de criterios de aceptación claros, errores en la integración continua y fallas críticas el día del lanzamiento. Esto generó indisponibilidad del servicio, duplicación de operaciones y fallas en autenticación.

4.2 Actividades principales del proceso

1. **Levantamiento y definición de requerimientos:** Identificación de necesidades del negocio, elaboración de historias de usuario y criterios de aceptación. Se detectó falta de claridad y ausencia de validación formal.

2. **Diseño técnico y funcional:** Definición de arquitectura, flujos, mockups y wireframes. No se elaboraron prototipos funcionales validados por usuarios clave ni por QA.
3. **Desarrollo de software:** Construcción de módulos de autenticación, portafolio, operaciones de inversión, integración con servicios externos y manejo de datos.
4. **Pruebas de calidad:** Pruebas unitarias, funcionales, de seguridad, de carga y de usabilidad. En la práctica, varias pruebas críticas no fueron ejecutadas o se realizaron tardíamente.
5. **Implementación y despliegue:** Publicación en App Store y Google Play. Se evidenció falta de entornos segregados adecuados y ausencia de pipeline automatizado con controles de calidad.
6. **Monitoreo y mantenimiento:** Gestión de incidentes, aplicación de parches, monitoreo de disponibilidad, rendimiento y seguridad. Durante las 48 horas posteriores al lanzamiento ocurrieron fallas masivas debido a la falta de pruebas de capacidad.

4.3 Entradas del proceso

- Requerimientos del negocio y del Product Owner.
- Historias de usuario y criterios de aceptación.
- Políticas y lineamientos de Seguridad de la Información (ISO 27001, SBS).
- Código fuente y documentación técnica.
- Ambientes de desarrollo, QA, preproducción y producción.
- Matrices de riesgos e indicadores tecnológicos.

4.4 Salidas del proceso

- Aplicación móvil Finversión operativa en iOS y Android.
- Documentación técnica, manuales funcionales y de usuario.
- Versiones liberadas del sistema mediante CI/CD.
- Informes de pruebas funcionales, de seguridad y de rendimiento.
- Registros de monitoreo, bitácoras de incidentes y reportes post-mortem.
- Planes y reportes de respaldo, recuperación y restauración.

5 Objetivo general de la auditoría

Evaluar la efectividad de los controles implementados durante el desarrollo, pruebas y despliegue de la aplicación móvil Finversión de SOL PERÚ S.A., con el fin de determinar si fueron adecuados para prevenir el incidente crítico del 15 de abril de 2025 y para asegurar la calidad, disponibilidad, integridad y seguridad del servicio de inversión digital ofrecido a los clientes.

6 Alcance de la auditoría

Período Auditado: La auditoría cubre desde el inicio del proyecto Finversión en marzo de 2025 hasta el 15 de mayo de 2025, incluyendo un mes posterior al incidente para evaluar las acciones correctivas implementadas.

El alcance de la auditoría comprende la evaluación de los procesos, controles y prácticas implementadas durante el desarrollo, aseguramiento de la calidad, pruebas técnicas y despliegue de la aplicación móvil Finversión de SOL PERÚ S.A., enfocado en los elementos que contribuyeron al incidente del 15 de abril de 2025. La auditoría abarca tanto los procesos operativos y tecnológicos relacionados al ciclo de vida del software, como las actividades de soporte e infraestructura sobre las cuales depende la disponibilidad y continuidad del servicio.

En primer lugar, se revisará el proceso de definición y gestión de requisitos, considerando las historias de usuario elaboradas por el Product Owner, la claridad y trazabilidad de los criterios de aceptación, la existencia y calidad de la documentación visual (mockups, wireframes y prototipos), así como la identificación y análisis de riesgos durante la fase de diseño siguiendo la norma ISO 31000. Asimismo, se evaluará el proceso de aseguramiento de calidad (QA), verificando el grado de participación del área en las fases de diseño, desarrollo y pruebas, la existencia de validaciones semanales y reportes de defectos, la efectividad de las pruebas funcionales y de regresión, y la alineación del proceso con las prácticas recomendadas por COBIT 2019.

La auditoría también contempla la revisión de las pruebas de diseño y usabilidad, evaluando la validación de los prototipos con usuarios internos y piloto, así como el correcto funcionamiento de los flujos críticos de la aplicación, incluyendo el inicio de sesión, las operaciones de inversión y la visualización de portafolios. Se analizará la existencia de inconsistencias entre los diseños aprobados y la funcionalidad finalmente implementada. De igual manera, se realizará una evaluación de las pruebas técnicas no funcionales, tales como pruebas de carga, estrés, concurrencia y degradación del sistema, verificando la capacidad de infraestructura, los mecanismos de balanceo de carga, la redundancia, la alta disponibilidad y el monitoreo en tiempo real de los recursos críticos. También se evaluarán los resultados de pruebas realizadas en ambientes equivalentes a producción, conforme a la norma ISO/IEC 27100.

Adicionalmente, se revisarán los procesos de despliegue y continuidad operativa, incluyendo los procedimientos de despliegue, rollback y recuperación ante fallas; la existencia y ejecución de planes de respuesta a incidentes; la gestión de ambientes de desarrollo, QA, preproducción y producción; y las políticas internas relacionadas con la continuidad del negocio y la gestión de incidentes tecnológicos. Finalmente, se analizará la documentación técnica y evidencia operativa relevante, como el backlog, los artefactos del ciclo ágil, los informes de QA, los reportes de fallas, las bitácoras de incidentes, los logs de auditoría, las configuraciones de infraestructura, las métricas de rendimiento y los registros de participación de stakeholders y equipos técnicos.

En el presente informe queda fuera del alcance de la auditoría la revisión financiera de operaciones reales realizadas por los clientes, la auditoría del sistema core bancario de SOL PERÚ S.A., la evaluación

del área de marketing o de la gestión de comunicaciones externas y el análisis forense del incidente posterior al retiro de la aplicación de las tiendas móviles.

7 Criterios de la auditoría

7.1 Explicación detallada del criterio 1: ISO 31000 – Gestión de Riesgos

El criterio se fundamenta en la norma ISO 31000, la cual establece principios para la gestión de riesgos en las organizaciones. Esta norma busca que las decisiones como el diseño, desarrollo e implementación de soluciones tecnológicas se realicen considerando la identificación, análisis, evaluación y tratamiento de riesgos. En el presente caso, la auditoría evaluará si el proceso de definición y gestión de requisitos funcionales críticos, liderado por el Product Owner (PO), incorpora de manera explícita la identificación y análisis de riesgos asociados al uso de la aplicación, tales como errores en las funcionalidades de inversión, duplicación de operaciones, inconsistencias en la visualización de portafolios o fallos en la autenticación de usuarios. Se verificará que los riesgos sean considerados desde la fase de diseño del sistema, que existan planes de mitigación documentados y que los controles asociados a los riesgos críticos por ejemplo, mockups validados, criterios de aceptación claros, revisiones formales de requerimientos y pruebas funcionales estructuradas estén implementados y operen de manera efectiva. Asimismo, se analizará si las políticas y procedimientos internos de SOL PERÚ S.A. se encuentran alineados con los principios de ISO 31000, de modo que la gestión de requisitos contribuya a minimizar riesgos operativos y tecnológicos, reducir la probabilidad de incidentes como los ocurridos en el lanzamiento de FInversión y fortalecer la continuidad y seguridad de los servicios financieros digitales ofrecidos a los clientes.

7.2 Explicación detallada del criterio 2: COBIT 2019 – Gobierno y Gestión de TI

El criterio se fundamenta en COBIT 2019, un marco integral que establece principios, objetivos de gobierno y prácticas para asegurar que las tecnologías de la información contribuyan de manera efectiva al logro de los objetivos del negocio. COBIT 2019 promueve la alineación entre estrategia, riesgos, control y desempeño del área de TI. La auditoría evaluará si la integración del área de Aseguramiento de Calidad (QA) dentro del ciclo de desarrollo del sistema FInversión se realiza de forma oportuna y estructurada, garantizando que los procesos de QA aporten a la calidad, confiabilidad y control de los desarrollos. Esto incluye revisar si QA participa desde etapas tempranas del ciclo ágil (definición, diseño, pruebas y despliegue), tal como recomiendan los componentes de gobierno y gestión de COBIT. Se verificará además si existe alineación entre QA y los objetivos estratégicos del negocio, la disponibilidad de procedimientos claros para la revisión y aprobación de entregables, y la aplicación sistemática de controles que mitiguen riesgos asociados a defectos funcionales, errores en producción o fallas de integridad en los servicios financieros. Asimismo, se analizará si las políticas internas de SOL PERÚ S.A. están alineadas con los principios de COBIT 2019, garantizando una adecuada gobernanza, una correcta gestión de riesgos tecnológicos, y la mejora continua de la eficiencia y calidad en el ciclo de desarrollo del sistema FInversión.

7.3 Explicación detallada del criterio 3: ISO/IEC 27100 – Visión general de ciberseguridad

El criterio se fundamenta en la norma ISO/IEC 27100, la cual establece principios y lineamientos generales para la gestión de la ciberseguridad, enfatizando la protección de los sistemas de información, la resiliencia tecnológica y la continuidad operativa frente a amenazas internas o externas. Esta norma sirve como base para evaluar la capacidad de una organización para anticipar, resistir, recuperarse y adaptarse ante incidentes de ciberseguridad o fallos tecnológicos. En el contexto de la aplicación móvil Finversión, la auditoría evaluará si las pruebas técnicas no funcionales realizadas incluyendo pruebas de carga, estrés, disponibilidad y comportamiento bajo alta concurrencia son adecuadas para garantizar la resiliencia, disponibilidad y continuidad operativa del sistema. Esto implica verificar si las pruebas simulan condiciones extremas similares a las que enfrentó la aplicación durante su lanzamiento, cuando más de 50.000 usuarios generaron sobrecarga y caídas del servicio. La auditoría también analizará si los escenarios de prueba permiten identificar vulnerabilidades de rendimiento, posibles cuellos de botella, fallas en la arquitectura o debilidades de infraestructura, así como la existencia de medidas preventivas o correctivas orientadas a mitigar riesgos asociados a la degradación del servicio, interrupciones operativas o pérdida de integridad transaccional. Finalmente, se verificará si las políticas y procedimientos internos de SOL PERÚ S.A. están alineados con los principios de ISO/IEC 27100, asegurando una gestión adecuada de la ciberseguridad, la protección de los activos críticos, la capacidad de respuesta ante incidentes y la continuidad de los servicios financieros digitales ofrecidos a los clientes.

8 Objetivos específicos de la auditoría

8.1 Objetivo específico 1:

Evaluar la eficacia del proceso de definición, diseño y validación de los requisitos funcionales críticos de la aplicación, verificando si el Product Owner y el equipo de desarrollo establecieron historias de usuario claras y buenos criterios de aceptación.

8.2 Objetivo específico 2:

Verificar la efectividad y oportunidad de la integración del área de Aseguramiento de Calidad (QA) en el ciclo de desarrollo de Finversión, evaluando si las pruebas funcionales y de usabilidad (incluyendo mockups, prototipos y validación con usuarios piloto) fueron suficientes.

8.3 Objetivo específico 3:

Comprobar la suficiencia de las pruebas técnicas no funcionales realizadas a Finversión, con énfasis en las pruebas de estrés, carga de servidores y capacidad de infraestructura para soportar el tráfico esperado de más de 50,000 usuarios simultáneos.

9 Riesgos de auditoría – Controles existentes

En la presente sección se presenta un riesgo identificado por cada objetivo específico y cada riesgo cuenta con tres controles de tipo preventivo, detectivo y correctivo.

9.1 Objetivo específico 1

9.1.1 Riesgo 1: Ausencia de mockups, wireframes y prototipo funcional validado.

Figura 2

Matriz de Riesgos para el objetivo específico 1.

Macroproceso / Servicio	Proceso / Producto	Descripción del riesgo (Evento de Riesgo)	Declaración del Riesgo (NO BORRAR FÓRMULA)	Tipo de Riesgo	Causa(s) Amenaza y Vulnerabilidad	Factor del Riesgo Externo	Factor del Riesgo	Consecuencias	Tipo de Impacto (Categorías de Consecuencia)	Probabilidad	Impacto	Nivel de Riesgo Inherente	Tratamiento de Riesgo
Continuidad de Negocio y de TI	Pruebas de rendimiento y disponibilidad	Caidas de sistema constantes y bajo rendimiento en horas de alto tráfico	Probabilidad que Caidas de sistema constantes y bajo rendimiento en horas de alto tráfico(debido a /debido a que) No se estableció un procedimiento formal para la validación de rendimiento previo al despliegue; que genera Pérdida de clientes y posibles multas por reclamos de la SBS	Operativo - Tecnológico	No se estableció un procedimiento formal para la validación de rendimiento previo al despliegue	Tecnológico	Sistemas de información	Pérdida de clientes y posibles multas por reclamos de la SBS	3.1 Legal/Multas	Casi seguro	Catastrófico	Extremo	Reducir la probabilidad

9.1.1.1 Control 1 para el Riesgo 1

Figura 3

Matriz de control 1 para el riesgo del objetivo específico 1.

Controles Existentes (si el Caso lo indica) o Controles Propuestos	Tipo de Control	Clase de Control	Frecuencia (Meses)	Descripción (Meses)	Responsable del Control (Meses)	Justificación (Meses)	Indicadores (Meses)	Evaluación Efectividad del Control	Afecta Probabilidad	Afecta Impacto	Probabilidad	Impacto	Nivel de Riesgo Residual
Quincenal se realiza Antes de iniciar el desarrollo, el área de Diseño UX/UI elabora mockups y wireframes para cada módulo crítico del sistema. por parte de (l) Diseñador de software con el objetivo de Contar con referencias de diseño validados reduce errores funcionales o interfaces mal especificadas. El control se evidencia mediante el indicador KRI= número de	Preventivo	Dependiente de TI	Quincenal	Antes de iniciar el desarrollo, el área de Diseño UX/UI elabora mockups y wireframes para cada módulo crítico del sistema.	Diseñador de software	Contar con referencias de diseño validados reduce errores funcionales o interfaces mal especificadas	KRI= número de módulos sin mockups aprobados / total de módulos	1.No se aplica	Si	Si	Improbable	Mayor	Alto

9.1.1.2 Control 2 para el Riesgo 1

Figura 4

Matriz de control 2 para el riesgo del objetivo específico 1.

Semanal se realiza El área de QA valida que las pantallas y flujos implementados en el software coincidan con los mockups y wireframes aprobados por parte de(l)Área de QA con el objetivo de Detectar desviaciones entre el diseño aprobado y lo implementado en el software . El control se evidencia mediante el indicador KRI= inconsistencias encontradas /	Detectivo	Dependiente de TI	Semanal	El área de QA valida que las pantallas y flujos implementados en el software coincidan con los mockups y wireframes aprobados	Área de QA	Detectar desviaciones entre el diseño aprobado y lo implementado en el software	KRI= inconsistencias encontradas / funcionalidades terminadas	1.No se aplica	Si	Si	Improbable	Mayor	Alto
--	-----------	-------------------	---------	---	------------	---	---	----------------	----	----	------------	-------	------

9.1.1.3 Control 3 para el Riesgo 1

Figura 5

Matriz de control 3 para el riesgo del objetivo específico 1.

Cuando se requiera se realiza al detectar inconsistencias entre la interfaz implementada y los mockups aprobados, se actualiza el diseño técnico y se corrige el prototipo por parte de(l)Equipo de desarrollo con el objetivo de Asegurar que las pantallas y flujos del sistema se ajusten a la arquitectura definida. El control se evidencia mediante el indicador KRI= solicitudes de corrección de diseño técnico / componente de la	Correctivo	Dependiente de TI	Cuando se requiera	al detectar inconsistencias entre la interfaz implementada y los mockups aprobados, se actualiza el diseño técnico y se corrige el prototipo	Equipo de desarrollo	Asegurar que las pantallas y flujos del sistema se ajusten a la arquitectura definida	KRI= solicitudes de corrección de diseño técnico / componente de la aplicación	1.No se aplica	Si	Si	Probable	Mayor	Extremo
--	------------	-------------------	--------------------	--	----------------------	---	--	----------------	----	----	----------	-------	---------

9.2 Objetivo específico 2

9.2.1 Riesgo 2: Participación tardía del área de QA.

Figura 6

Matriz de Riesgos para el objetivo específico 2.

Macroproceso / Servicio	Proceso / Producto	Descripción del riesgo (Evento de Riesgo)	Declaración del Riesgo (NO BORRAR FÓRMULA)	Tipo de Riesgo	Causa(s) Amenaza y Vulnerabilidad	Factor del Riesgo Externo	Factor del Riesgo	Consecuencias	Tipo de Impacto (Categorías de Consecuencia)	Probabilidad	Impacto	Nivel de Riesgo Inherente	Tratamiento de Riesgo
Desarrollo de Programas	Aseguramiento de la calidad	Defectos de funcionalidad en la aplicación lleguen a producción	Probabilidad que Defectos de funcionalidad en la aplicación lleguen a producción(debido a /debido a que) la falta de compromiso del área de QA y falta de pruebas del sistema que genera fallas en producción como duplicación de operaciones y errores no detectados	Operativo - Tecnológico	la falta de compromiso del área de QA y falta de pruebas del sistema	Tecnológico	Sistemas de información	Fallas en producción como duplicación de operaciones y errores no detectados	2.5.Credibilidad o imagen/Usuario/ país	Casi seguro	Mayor	Extremo	Reducir la probabilidad

9.2.1.1 Control 1 para el Riesgo 2

Figura 7

Matriz de control 1 para el riesgo del objetivo específico 2.

Controles Existentes (si el Caso lo indica) o Controles Propuestos	Tipo de Control	Clase de Control	Frecuencia (Meses)	Descripción (Meses)	Responsable del Control (Meses)	Justificación (Meses)	Indicadores (Meses)	Evaluación Efectividad del Control	Afecta Probabilidad	Afecta Impacto	Probabilidad	Impacto	Nivel de Riesgo Residual
Semanal se realiza Impulsar la participación del QA en todas las fases del desarrollo por parte de(l)Scrum Master con el objetivo de asegurar la calidad del código y de las funcionalidades de la aplicación. El control se evidencia mediante el indicador KRI= funcionalidades verificadas / funcionalidades totales	Preventivo	Manual	Semanal	Impulsar la participación del QA en todas las fases del desarrollo	Scrum Master	asegurar la calidad del código y de las funcionalidades de la aplicación	KRI= funcionalidades verificadas / funcionalidades totales	1.No se aplica	Si	Si	Improbable	Mayor	Alto

9.2.1.2 Control 2 para el Riesgo 2

Figura 8

Matriz de control 2 para el riesgo del objetivo específico 2.

Diario se realiza Se realiza diariamente pruebas de regresión automáticamente para detectar errores funcionales por parte de(l)Area de TI con el objetivo de Se asegura de detectar errores y verificar cambios en tiempo real y continuamente. El control se evidencia mediante el indicador KRI= tasa de fallas detectadas / total de ejecuciones de código	Detectivo	Automático	Diario	Se realiza diariamente pruebas de regresión automáticamente para detectar errores funcionales	Area de TI	Se asegura de detectar errores y verificar cambios en tiempo real y continuamente	KRI= tasa de fallas detectadas / total de ejecuciones de código	1.No se aplica	Si	Si	Improbable	Moderado	Moderado
---	-----------	------------	--------	---	------------	---	---	----------------	----	----	------------	----------	----------

9.2.1.3 Control 3 para el Riesgo 2

Figura 9

Matriz de control 3 para el riesgo del objetivo específico 2.

Cuando se requiera se realiza Tras un incidente en la aplicación se realizara una analisis contemplando nuevos casos de prueba para evitar errores del mismo tipo a futuro por parte de(l)Lider de QA con el objetivo de Mejorar la robustez de la aplicación ante distintos casos de uso. El control se evidencia mediante el indicador KRI= reincidencia de defectos críticos	Correctivo	Manual	Cuando se requiera	Tras un incidente en la aplicación se realizara una analisis contemplando nuevos casos de prueba para evitar errores del mismo tipo a futuro	Lider de QA	Mejorar la robustez de la aplicación ante distintos casos de uso	KRI= reincidencia de defectos críticos	1.No se aplica	Si	Si	Improbable	Mayor	Alto
---	------------	--------	--------------------	--	-------------	--	--	----------------	----	----	------------	-------	------

9.3 Objetivo específico 3

9.3.1 Riesgo 3: Omisión de pruebas de estrés.

Figura 10

Matriz de Riesgos para el objetivo específico 3.

Macroproceso / Servicio	Proceso / Producto	Descripción del riesgo (Evento de Riesgo)	Declaración del Riesgo (NO BORRAR FÓRMULA)	Tipo de Riesgo	Causa(s) Amenaza y Vulnerabilidad	Factor del Riesgo Externo	Factor del Riesgo	Consecuencias	Tipo de Impacto (Categorías de Consecuencia)	Probabilidad	Impacto	Nivel de Riesgo inherente	Tratamiento de Riesgo
Continuidad de Negocio y de TI	Pruebas de rendimiento y disponibilidad	Caídas de sistema constantes y bajo rendimiento en horas de alto tráfico	Probabilidad que Caídas de sistema constantes y bajo rendimiento en horas de alto tráfico(debido a /debido a que) No se estableció un procedimiento formal para la validación de rendimiento previo al despliegue;lo que genera Pérdida de clientes y posibles multas por reclamos de la SBS	Operativo - Tecnológico	No se estableció un procedimiento formal para la validación de rendimiento previo al despliegue	Tecnológico	Sistemas de información	Pérdida de clientes y posibles multas por reclamos de la SBS	3.1 Legal/Multas	Casi seguro	Mayor	Extremo	Reducir la probabilidad

9.3.1.1 Control 1 para el Riesgo 3

Figura 11

Matriz de control 1 para el riesgo del objetivo específico 3.

Controles Existentes (si el Caso lo indica) o Controles Propuestos	Tipo de Control	Clase de Control	Frecuencia (Meses)	Descripción (Meses)	Responsable del Control (Meses)	Justificación (Meses)	Indicadores (Meses)	Evaluación Efectividad del Control	Afecta Probabilidad	Afecta Impacto	Probabilidad	Impacto	Nivel de Riesgo Residual
Mensual se realiza ejecutar pruebas de carga y estrés en entornos identicos a producción por parte de(l)Equipo de infraestructura con el objetivo de Prevenir saturación o caídas del sistema ante alta concurrencia. El control se evidencia mediante el indicador KRI= % de cumplimiento de pruebas de carga programadas	Preventivo	Dependiente de TI	Mensual	ejecutar pruebas de carga y estrés en entornos identicos a producción	Equipo de infraestructura	Prevenir saturación o caídas del sistema ante alta concurrencia	KRI= % de cumplimiento de pruebas de carga programadas	2.Se aplica pero no efectivo	Si	Si	Posible	Mayor	Extremo

9.3.1.2 Control 2 para el Riesgo 3

Figura 12

Matriz de control 2 para el riesgo del objetivo específico 3.

Diario se realiza monitoreo automático en tiempo real del uso de CPU, memoria y tráfico por parte de(l)Equipo de TI con el objetivo de Detectar con anticipación indicios de sobrecarga de la aplicación. El control se evidencia mediante el indicador KRI= alertas críticas generadas / mes	Detectivo	Automático	Diario	monitoreo automático en tiempo real del uso de CPU, memoria y tráfico	Equipo de TI	Detectar con anticipación indicios de sobrecarga de la aplicación	KRI= alertas críticas generadas / mes	2.Se aplica pero no efectivo	Si	Si	Improbable	Moderado	Moderado
---	-----------	------------	--------	---	--------------	---	---------------------------------------	------------------------------	----	----	------------	----------	-----------------

9.3.1.3 Control 3 para el Riesgo 3

Figura 13

Matriz de control 3 para el riesgo del objetivo específico 3.

Cuando se requiera se realiza ejecutar plan de recuperación y rollback, restaurando la versión previa del sistema por parte de(l)Equipo de desarrollo con el objetivo de Restaurar el servicio en el menor tiempo posible para mitigar impacto en usuarios y cumplir con la SBS. El control se evidencia mediante el indicador KRI= tiempo promedio de recuperación	Correctivo	Dependiente de TI	Cuando se requiera	ejecutar plan de recuperación y rollback, restaurando la versión previa del sistema	Equipo de desarrollo	Restaurar el servicio en el menor tiempo posible para mitigar impacto en usuarios y cumplir con la SBS	KRI= tiempo promedio de recuperación	2.Se aplica pero no efectivo	Si	Si	Posible	Mayor	Extremo
---	------------	-------------------	--------------------	---	----------------------	--	--------------------------------------	------------------------------	----	----	---------	-------	---------

10 Técnicas de pruebas de controles

10.1 Control 1 (Preventivo): Elaboración obligatoria de mockups y wireframes previos al desarrollo.

10.1.1 Técnica 1 – SNAPSHOT

Descripción: Permite capturar el estado de los diseños aprobados (mockups) antes de iniciar el desarrollo, verificando que existan, estén completos y alineados con requisitos.

10.1.2 Técnica 2 – CIS (Simulación Intermitente)

Descripción: Permite simular escenarios de diseño y verificar si las pantallas derivadas coinciden con los prototipos obligatorios antes del desarrollo.

10.2 Control 2 (Detectivo): Validación semanal de diseños implementados por el área de QA.

10.2.1 Técnica 1 – SCARF

Descripción: Permite revisar registros automáticos de validaciones y detectar discrepancias entre diseño aprobado y diseño implementado.

10.2.2 Técnica 2 – SNAPSHOT

Descripción: Captura estados de pantallas o flujos construidos para compararlos con los diseños aprobados durante las validaciones semanales.

10.3 Control 3 (Correctivo): Actualización del diseño técnico y corrección del prototipo ante inconsistencias detectadas.

10.3.1 Técnica 1 – ITF (Integrated Test Facility)

Descripción: Permite validar si las correcciones técnicas aplicadas funcionan correctamente generando datos ficticios para probar el prototipo corregido.

10.3.2 Técnica 2 – CIS (Simulación en paralelo)

Descripción: Simula el comportamiento antes y después de la corrección para verificar que el diseño técnico actualizado resuelve la inconsistencia.

10.4 Control 4 (Preventivo): Participación del área de QA en todas las fases del desarrollo.

10.4.1 Técnica 1 – SNAPSHOT

Descripción: Captura evidencias de participación (revisiones, reuniones, aprobaciones) en puntos clave del ciclo de vida.

10.4.2 Técnica 2 – Ganchos de Auditoría

Descripción: Permite registrar eventos clave de QA dentro del flujo (revisión de requisitos, testing inicial) para asegurar que participan desde etapas tempranas.

10.5 Control 5 (Detectivo): Ejecución diaria de pruebas de regresión automatizadas.

10.5.1 Técnica 1 – SCARF

Descripción: Revisa registros automáticos generados por el motor de pruebas para detectar fallas funcionales o cambios no controlados.

10.5.2 Técnica 2 – CIS

Descripción: Permite evaluar tendencias de errores y verificar consistencia de resultados entre diferentes días de ejecución.

10.6 Control 6 (Correctivo): Análisis post-incidente y ampliación de casos de prueba para evitar recurrencia.

10.6.1 Técnica 1 – SNAPSHOT

Descripción: Captura eventos asociados al incidente y evidencia la creación y ejecución de nuevos casos de prueba después del problema.

10.6.2 Técnica 2 – ITF

Descripción: Permite probar los nuevos casos mediante datos de prueba simulados para confirmar que el incidente no vuelve a ocurrir.

10.7 Control 7 (Preventivo): Ejecución mensual de pruebas de carga y estrés en entornos equivalentes a producción

10.7.1 Técnica 1 – SNAPSHOT

Descripción: Captura métricas de rendimiento en puntos críticos durante las pruebas de carga.

10.7.2 Técnica 2 – CIS

Descripción: Simula cargas continuas e intermitentes a lo largo del tiempo para validar capacidad bajo distintos niveles de estrés.

10.8 Control 8 (Detectivo): Monitoreo automático diario de recursos críticos del sistema en tiempo real.

10.8.1 Técnica 1 – SCARF

Descripción: Registra y analiza eventos relacionados con CPU, memoria, I/O y detecta patrones anómalos.

10.8.2 Técnica 2 – Ganchos de Auditoría

Descripción: Se activan ante eventos críticos, como uso excesivo de recursos, generando alertas en tiempo real.

10.9 Control 9 (Correctivo): Ejecución del plan de recuperación y rollback ante incidentes de rendimiento.

10.9.1 Técnica 1 – ITF

Descripción: Permite simular fallas controladas y ejecutar el rollback usando datos ficticios para validar su efectividad.

10.9.2 Técnica 2 – SNAPSHOT

Descripción: Captura estados del sistema antes, durante y después del rollback para validar la integridad de la recuperación.

11 Fuentes de donde se va a tomar la evidencia

11.1 Fuente para la técnica SNAPSHOT en el Control 1 (Mockups y wireframes)

Fuente: Repositorio de diseño de la aplicación FIversión (Figma, Adobe XD o similar) con versiones fechadas y logs de aprobación de mockups y wireframes.

Procedimiento:

1. Acceder al repositorio de diseño del proyecto FIversión.
2. Verificar la existencia de mockups y wireframes aprobados previos al inicio del desarrollo.
3. Capturar evidencia de las fechas de creación, modificación y aprobación.
4. Validar que cada pantalla clave del sistema cuente con su respectivo diseño documentado.
5. Documentar los resultados con capturas de pantalla y exportación de metadatos del repositorio.

11.2 Fuente para la técnica CIS - Simulación Intermitente en el Control 1 (Mockups y wireframes)

Fuente: Entorno de staging de Finversión con builds de diferentes etapas del desarrollo y herramientas de comparación visual automatizada.

Procedimiento:

1. Acceder al entorno de staging con versiones históricas de la aplicación.
2. Ejecutar herramientas de testing visual para comparar pantallas implementadas vs. mockups aprobados.
3. Simular diferentes flujos de usuario y capturar discrepancias.
4. Generar reportes automáticos de diferencias detectadas.
5. Documentar hallazgos con capturas comparativas lado a lado.

11.3 Fuente para la técnica SCARF en el Control 2 (Validación semanal QA)

Fuente: Sistema de gestión de defectos (Jira, Azure DevOps) con registros de validaciones semanales del área de QA durante el desarrollo de Finversión.

Procedimiento:

1. Acceder al sistema de gestión de proyectos y filtrar por tickets del área de QA.
2. Revisar los registros de validaciones semanales con fechas y responsables.
3. Verificar que existan evidencias de discrepancias detectadas entre diseño y desarrollo.
4. Confirmar que los hallazgos contengan severidad, módulo afectado y estado de resolución.
5. Exportar reportes consolidados con métricas de calidad por sprint.

11.4 Fuente para la técnica SNAPSHOT en el Control 2 (Validación semanal QA)

Fuente: Actas de reuniones semanales de QA y repositorio de evidencias con screenshots de validaciones realizadas en Finversión.

Procedimiento:

1. Recopilar actas de reuniones semanales del equipo de QA durante el proyecto.
2. Acceder al repositorio de evidencias de QA con capturas de pantalla fechadas.
3. Validar que cada sprint cuente con evidencia de revisión de QA.
4. Verificar que las capturas incluyan información de usuario, fecha, módulo y observaciones.
5. Consolidar evidencias en un informe cronológico por fase del proyecto.

11.5 Fuente para la técnica ITF - Integrated Test Facility en el Control 3 (Corrección de prototipos)

Fuente: Entorno de pruebas integrado de FInversión con bases de datos de prueba y scripts de validación de correcciones.

Procedimiento:

1. Configurar el entorno ITF con datos ficticios de usuarios, portafolios e inversiones.
2. Identificar prototipos que requirieron corrección durante el desarrollo.
3. Ejecutar scripts de prueba con datos sintéticos para validar las correcciones aplicadas.
4. Verificar que los problemas originales hayan sido resueltos sin generar nuevos defectos.
5. Documentar los resultados de las pruebas con logs de ejecución y capturas de pantalla.

11.6 Fuente para la técnica CIS - Simulación en paralelo en el Control 3 (Corrección de prototipos)

Fuente: Entornos paralelos de FInversión (versión anterior vs. versión corregida) con herramientas de análisis diferencial.

Procedimiento:

1. Preparar dos entornos idénticos: uno con la versión original y otro con la corrección aplicada.
2. Ejecutar el mismo conjunto de transacciones en ambos entornos simultáneamente.
3. Comparar resultados, tiempos de respuesta y comportamiento funcional.
4. Analizar los logs para identificar mejoras o efectos secundarios de la corrección.
5. Generar informe comparativo con métricas de rendimiento y funcionalidad.

11.7 Fuente para la técnica SNAPSHOT en el Control 4 (Participación de QA)

Fuente: Sistema de gestión de proyectos (Jira, Confluence) con registros de asistencia de QA a ceremonias ágiles y asignación de tareas en FInversión.

Procedimiento:

1. Acceder al calendario del proyecto y extraer registros de asistencia a reuniones.
2. Revisar actas de daily standups, sprint planning, reviews y retrospectives.
3. Verificar la participación de miembros del área de QA en cada ceremonia.
4. Consultar el backlog para confirmar tareas asignadas a QA en todas las fases del sprint.
5. Documentar evidencia con capturas de pantalla de calendarios, actas y asignaciones.

11.8 Fuente para la técnica Ganchos de Auditoría en el Control 4 (Participación de QA)

Fuente: Pipeline de CI/CD de FInversión con logs de eventos y aprobaciones obligatorias del área de QA en gates de calidad.

Procedimiento:

1. Acceder al sistema de integración continua (Jenkins, GitLab CI, Azure DevOps).
2. Revisar la configuración de gates de calidad que requieren aprobación de QA.
3. Extraer logs de eventos donde QA intervino para aprobar o rechazar despliegues.
4. Verificar que existan timestamps, usuarios de QA y criterios de aprobación documentados.

11.9 Fuente para la técnica SCARF en el Control 5 (Pruebas de regresión)

Fuente: Servidor de integración continua (Jenkins, GitLab CI) con logs de ejecuciones diarias de pruebas automatizadas de regresión en FInversión.

Procedimiento:

1. Acceder al servidor de CI/CD y filtrar por jobs de pruebas de regresión.
2. Revisar los logs de ejecuciones diarias durante el período de desarrollo.
3. Analizar registros de pruebas fallidas, tasas de éxito y cobertura de código.
4. Verificar que las pruebas se ejecuten de forma automatizada sin intervención manual.
5. Exportar reportes históricos con tendencias de calidad y regresiones detectadas.

11.10 Fuente para la técnica CIS en el Control 5 (Pruebas de regresión)

Fuente: Dashboard de métricas de calidad con análisis de tendencias de resultados de pruebas automatizadas en FInversión.

Procedimiento:

1. Acceder al dashboard de calidad del proyecto (SonarQube, TestRail).
2. Revisar gráficos de tendencias de pruebas ejecutadas vs. exitosas vs. fallidas.
3. Analizar patrones de fallas recurrentes en módulos específicos.
4. Identificar sprints o fechas donde se detectaron aumentos anormales de regresiones.
5. Generar informe con análisis estadístico de la evolución de la calidad.

11.11 Fuente para la técnica SNAPSHOT en el Control 6 (Análisis post-incidente)

Fuente: Informe post-mortem del incidente del 15 de abril de 2025 y sistema de gestión de casos de prueba con nuevos test cases añadidos.

Procedimiento:

1. Obtener el informe oficial del Comité de Crisis sobre el incidente de lanzamiento.
2. Acceder al sistema de gestión de casos de prueba (TestRail, Zephyr).
3. Identificar casos de prueba creados específicamente después del incidente.
4. Verificar que los nuevos casos aborden las causas raíz identificadas.
5. Documentar la trazabilidad entre hallazgos del incidente y casos de prueba creados.

11.12 Fuente para la técnica ITF en el Control 6 (Análisis post-incidente)

Fuente: Entorno de pruebas de Flversión configurado para reproducir las condiciones del incidente con datos sintéticos.

Procedimiento:

1. Configurar un entorno que replique la arquitectura y carga del día del incidente.
2. Crear datos ficticios que simulen más de 50.000 usuarios concurrentes.
3. Ejecutar los nuevos casos de prueba creados post-incidente con estos datos.
4. Verificar que las medidas correctivas implementadas previenen la recurrencia.
5. Documentar resultados con logs de rendimiento, capturas y análisis de comportamiento.

11.13 Fuente para la técnica SNAPSHOT en el Control 7 (Pruebas de carga)

Fuente: Herramientas de pruebas de carga (JMeter, LoadRunner, Gatling) con reportes mensuales de pruebas de estrés realizadas a Flversión.

Procedimiento:

1. Acceder al repositorio de reportes de pruebas de carga del proyecto.
2. Verificar la existencia de pruebas mensuales previas al lanzamiento del 15 de abril.
3. Revisar métricas capturadas: usuarios concurrentes, tiempo de respuesta, throughput, tasa de error.
4. Validar que el entorno de pruebas sea equivalente al entorno productivo.
5. Documentar hallazgos con capturas de reportes y análisis de capacidad identificada.

11.14 Fuente para la técnica CIS en el Control 7 (Pruebas de carga)

Fuente: Scripts de simulación de carga con diferentes perfiles de usuario y reportes de saturación progresiva en FInversión.

Procedimiento:

1. Revisar los scripts de prueba de carga configurados para el proyecto.
2. Ejecutar simulaciones con incrementos graduales de usuarios (1K, 5K, 10K, 25K, 50K+).
3. Monitorear el comportamiento del sistema en cada nivel de carga.
4. Identificar el punto de saturación donde el sistema comienza a degradarse.
5. Generar informe con gráficos de rendimiento y umbrales de capacidad identificados.

11.15 Fuente para la técnica SCARF en el Control 8 (Monitoreo de recursos)

Fuente: Sistema de monitoreo en tiempo real (Prometheus, Grafana, Datadog, New Relic) con logs históricos de recursos de servidores de FInversión.

Procedimiento:

1. Acceder al sistema de monitoreo configurado para la infraestructura de FInversión.
2. Revisar dashboards con métricas de CPU, memoria, disco, red y latencia.
3. Analizar los logs de alertas generadas durante el período previo y durante el incidente.
4. Verificar que existan umbrales configurados para recursos críticos.
5. Exportar reportes con análisis de patrones anómalos y eventos de saturación.

11.16 Fuente para la técnica Ganchos de Auditoría en el Control 8 (Monitoreo de recursos)

Fuente: Sistema de alertas automáticas con webhooks configurados y logs de eventos críticos registrados en tiempo real en FInversión.

Procedimiento:

1. Revisar la configuración de reglas de alertas en el sistema de monitoreo.
2. Verificar que existan ganchos automáticos hacia canales de comunicación (Slack, email, PagerDuty).
3. Extraer logs de alertas disparadas automáticamente el 15 de abril de 2025.
4. Validar que las alertas contengan información de severidad, recurso afectado y timestamp.
5. Documentar la trazabilidad entre alertas generadas y respuesta del equipo técnico.

11.17 Fuente para la técnica ITF en el Control 9 (Plan de recuperación y rollback)

Fuente: Entorno de simulación de desastres con scripts de rollback documentados y logs de pruebas de recuperación de FInversión.

Procedimiento:

1. Configurar un entorno de pruebas que simule una falla crítica similar al incidente.
2. Ejecutar el procedimiento documentado de rollback utilizando scripts automatizados.
3. Validar que el sistema regrese a un estado operativo estable con datos ficticios.
4. Medir tiempos de recuperación (RTO) y verificar integridad de datos (RPO).
5. Documentar resultados con logs de ejecución, tiempos medidos y estado final del sistema.

11.18 Fuente para la técnica SNAPSHOT en el Control 9 (Plan de recuperación y rollback)

Fuente: Backups de base de datos y configuraciones de FInversión con logs del proceso de rollback ejecutado durante el incidente del 15-17 de abril de 2025.

Procedimiento:

1. Obtener copias de los backups utilizados durante el incidente real.
2. Acceder a los logs del sistema que documentan el proceso de rollback ejecutado.
3. Capturar evidencia de los estados del sistema antes, durante y después de la recuperación.
4. Verificar que los datos restaurados mantengan integridad y consistencia.
5. Validar que no se haya perdido información crítica de clientes durante el proceso.
6. Consolidar evidencia con capturas de pantalla, exports de base de datos y análisis de integridad.

12 Informe de auditoría

12.1 Opinión de auditoría

A continuación, se presentan las tres opiniones por cada uno de los tres controles seleccionados (uno por riesgo), de acuerdo con las técnicas aplicadas y la evidencia obtenida durante la auditoría del sistema FInversión.

12.1.1 Control 1 – Elaboración obligatoria de mockups y wireframes (OE1 – Riesgo 1)

Técnicas: SNAPSHOT – CIS

Opinión no calificada: La evidencia del repositorio de diseño confirma que todas las pantallas críticas contaban con mockups y wireframes completos, aprobados y alineados con los requisitos funcionales. El control opera consistentemente sin excepciones relevantes.

Opinión calificada: Se encontraron dos módulos secundarios sin diseño final validado, lo que evidencia una aplicación parcial del control. Aunque el diseño principal fue correctamente gestionado, el incumplimiento parcial justifica una opinión calificada.

Opinión adversa: La ausencia de mockups para flujos críticos y las discrepancias detectadas mediante CIS muestran que el control no operó durante el desarrollo inicial. Esta falla contribuyó directamente a los errores funcionales observados en producción.

12.1.2 Control 4 – Participación del área de QA en todas las fases del desarrollo (OE2 – Riesgo 2)

Técnicas: SNAPSHOT – Ganchos de Auditoría

Opinión no calificada: La evidencia demuestra participación activa de QA en todas las fases del ciclo ágil: reuniones, revisiones, pruebas tempranas y aprobaciones. Los registros de auditoría confirman su intervención constante. El control opera adecuadamente.

Opinión calificada: Se identificaron dos sprints donde QA no participó en ceremonias clave. Aunque la mayoría de fases sí contaron con su intervención, la inconsistencia obliga a emitir una opinión calificada.

Opinión adversa: La evidencia demuestra que QA ingresó tardíamente al proyecto (última semana). Esta omisión permitió que errores críticos evolucionaran sin detección temprana, razón por la cual se emite opinión adversa.

12.1.3 Control 7 – Ejecución mensual de pruebas de carga y estrés (OE3 – Riesgo 3)

Técnicas: SNAPSHOT – CIS

Opinión no calificada: Los reportes mensuales de pruebas de estrés confirman que el control se ejecutó correctamente en todos los meses auditados. Los resultados fueron consistentes y validados mediante CIS. El control opera apropiadamente.

Opinión calificada: Se constató la falta de reportes del mes previo al lanzamiento. Aunque los meses anteriores cuentan con evidencia adecuada, la omisión de la prueba más crítica genera una opinión calificada.

Opinión adversa: No se halló evidencia de pruebas de carga previas al lanzamiento. La falta total del control fue un factor clave en el colapso del sistema ante 50,000 usuarios. Se emite opinión adversa.

12.2 Principales hallazgos

De la evaluación realizada a los tres controles seleccionados (preventivo, detectivo y correctivo), se identificaron los siguientes hallazgos:

12.2.1 Hallazgo 1 – Inconsistencia en el diseño visual previo al desarrollo (Control 1)

Aunque el proceso de diseño está documentado, se hallaron módulos sin mockups finales o con diferencias respecto a lo implementado. En el peor escenario, no existía ningún diseño validado, lo cual afectó directamente la correcta construcción del sistema.

12.2.2 Hallazgo 2 – Participación irregular del área de QA (Control 4)

QA sí participó en parte del proyecto, pero su intervención fue tardía o incompleta en fases clave. En escenarios adversos, QA solo participó en la última semana, lo cual debilitó completamente la detección temprana de defectos.

12.2.3 Hallazgo 3 – Omisión o ejecución insuficiente de pruebas de carga (Control 7)

Las pruebas de estrés no se realizaron de manera consistente, y en el peor caso, no existían pruebas previas al lanzamiento, lo que permitió que el sistema colapsara bajo alta concurrencia.

12.3 Recomendaciones

En función de las opiniones emitidas y los hallazgos identificados, se presentan las siguientes recomendaciones, alineadas a ISO 31000, COBIT 2019 y ISO/IEC 27100:

12.3.1 Recomendación para Control 1 – Mockups y Wireframes

Se recomienda formalizar una política que obligue a validar y aprobar diseños, mockups y wireframes antes de iniciar el desarrollo. Además, integrar validaciones automáticas en el pipeline de CI/CD mediante comparaciones visuales para detectar desviaciones entre diseño y producto final. Todas las pantallas, sin excepción, deben contar con prototipos aprobados para asegurar consistencia funcional y evitar retrabajos.

12.3.2 Recomendación para Control 4 – Participación del área de QA

Se recomienda establecer la participación de QA como requisito obligatorio en todas las ceremonias Scrum, asegurando su intervención continua durante el ciclo de desarrollo. Asimismo, implementar alertas cuando QA no participe o no valide entregables, y estandarizar la trazabilidad mediante “quality gates” y registros automáticos dentro del pipeline de CI/CD, evitando el avance de versiones sin aprobación del área de calidad.

12.3.3 Recomendación para Control 7 – Pruebas de Carga y Estrés

Se recomienda definir un calendario periódico de pruebas de carga y rendimiento, incorporando escenarios de “load spike” y “stress peak” antes de cada despliegue. Estas pruebas deben integrarse como condición obligatoria del pipeline, de modo que ninguna versión sea publicada sin superar los mínimos requeridos de estabilidad y capacidad operativa.

13 Referencias APA

- Abdajabar, A., & Idbeaa, T. (2024). Cybercrime's Threat to Financial Institutions During COVID-19. *AlQalam Journal of Medical and Applied Sciences*, 46-52. <https://doi.org/10.54361/ajmas.2472207>
- Alnor, N. H. A., Al-Matari, E. M., Al-Bukhrani, M. A., Alhebri, A., Omer, A. M., & Mohammed, O. A. A. (2025). Assessing the Efficiency of the External Auditor in Combating Money Laundering in the Financial Sector Governance. *Journal of Governance and Regulation/Volume*, 14(1). <https://doi.org/10.22495/jgrv14i1siart3>
- Dajtnicka, E. W., Salsabila Helwani, Z., & Wulandari, D. (2025). Trust and Transparency: Auditor Independence and Financial Statement Integrity through the Lens of Business Ethics. *Jurnal Akuntansi Bisnis Pelita Bangsa*, 9(02), 222-234. <https://doi.org/10.37366/akubis.v9i02.2183>
- Herdiawan, R. A., Shonhadji, N., & Irwandi, S. A. (2024). The Influence of Auditor Professionalism, Independence, and Ethics on External Audit Quality. *JEMBA: Journal of Economics, Management, Business and Accounting*, 2(2), 1–18. <https://doi.org/10.54783/jemba.v2i2.38>
- ISO. (2018). *ISO 31000:2018 – Risk management — Guidelines*. International Organization for Standardization. <https://www.iso.org/standard/65694.html>
- ISO. (2020). *ISO/IEC TS 27100:2020 – Information technology — Cybersecurity — Overview and concepts*. International Organization for Standardization. <https://www.iso.org/standard/72434.html>
- ITSM-Docs. (2023). *COBIT 2019 PDF – Framework overview and resources*. <https://www.itsm-docs.com/blogs/cobit/cobit-2019-pdf>
- Olutimehin, A. T. (2025). Assessing the effectiveness of cybersecurity frameworks in mitigating cyberattacks in the banking sector and its applicability to decentralized finance (DeFi). *Available at SSRN 5133050*. <https://dx.doi.org/10.2139/ssrn.5133050>
- Prawiranegara, G. P. (2023). The Influence of Auditor Competence, Independence, and Ethics on Audit Quality: Survey in West Java Provincial Government Institutions. *Jurnal Ekonomi, Bisnis & Entrepreneurship (e-Journal)*, 17(1), 130–139. <https://doi.org/10.55208/jebe.v17i1.360>

14 Anexos

- Anexo A: Selección de Universo - Basado en Riesgos SOL PERU - Grupo 03

https://docs.google.com/spreadsheets/d/1e_G2cucjK4Ha91vAJ5jhWtoOABU0wJnH/edit?gid=956157604#gid=956157604

- Anexo B: Riesgos encontrados - Caso Sol Peru - Grupo 03

<https://docs.google.com/spreadsheets/d/1wXBcta1Lu1dME-NnnX9KmwIwjNGGp82V/edit?usp=sharing&ouid=104999296748249445387&rtpof=true&sd=true>

- Anexo C: Matriz de riesgos y controles - Aplicación móvil FIInversión - Grupo 03

<https://docs.google.com/spreadsheets/d/1vnWW-ykFTR3-SPSxFZE8O9XOgVaGfmyl/edit?usp=sharing&ouid=112798837448917373561&rtpof=true&sd=true>